

Table of Contents

Manual prático de recolha e auditoria de provas

Status da tradução: candidato de publicação assistido por máquina; não é apresentado como revisão linguística nativa.

Autor: Alberto “Al” Leiva ** Edição:** Inglês v1.0 ** Data de construção controlada:** 2026-08-01

O ChatGPT ajudou sob a direção do autor. O autor continua responsável pelas decisões editoriais e de divulgação.

** Anúncio escolar: ** Este manual fornece orientação profissional geral. Não constitui aconselhamento jurídico, regulamentar, contabilístico, de certificação ou de auditoria formal. Adaptar aos critérios, contratos, sistemas, dados, riscos e obrigações de retenção aplicáveis.

1. Governança e Princípios das Provas

1.1 Objectivo

Evidências suportam decisões sobre se um requisito, controle, processo ou compromisso é projetado adequadamente, implementado, operando como pretendido e produzindo o resultado esperado. As provas não são recolhidas apenas para preencher uma pasta ou satisfazer uma lista de verificação. Deve apoiar uma conclusão definida contra critérios identificados.

1.2 Governação de provas

A organização deve definir:

- Quem pode solicitar provas;
- Que possua cada elemento de prova;
- Que podem aprovar a divulgação;
- Sempre que possam ser armazenadas provas;
- O modo como os materiais sensíveis são classificados e protegidos;
- A forma como a autenticidade e a integridade são preservadas;
- O período de conservação das provas;
- A forma como as exceções e os litígios são agravados; e
- que aprova as respostas finais de auditoria.

O líder da auditoria ou avaliação continua a ser responsável pela estratégia de provas. Os proprietários do controle permanecem responsáveis pelo fornecimento de registros precisos e completos. Os guardas de provas protegem os sistemas de origem e os registros. Jurídico, privacidade, recursos humanos, segurança e especialistas em gerenciamento de registros devem ser envolvidos quando as evidências criam preocupações de confidencialidade, privilégio, trabalho, transfronteiriço ou retenção.

1.3 Qualidades essenciais das provas

Evidências úteis são:

- **relevante** — aborda directamente o critério e o objectivo de avaliação;
- **fiável** — origina-se de uma fonte confiável e pode ser corroborada;
- **** suficiente**** — existem provas suficientes para apoiar a conclusão e o período de amostragem;
- **apropriado** — a natureza e a qualidade dos elementos de prova correspondem ao risco e ao objectivo;
- **autêntico** — a evidência é o que afirma ser;
- **completo** — contexto, âmbito, datas, populações e limitações necessários estão presentes;
- **corrente** — os elementos de prova reflectem o período ou o ponto de tempo em causa;
- **Rastreável** — o revisor pode identificar o pedido, fonte, proprietário, critério, revisão e conclusão;
- **protegido** — são mantidas a confidencialidade, integridade, disponibilidade, privacidade e restrições legais; e
- **reprodutível** — um revisor qualificado pode entender como as evidências foram produzidas e chegar a uma conclusão suportável.

1.4 Hierarquia das provas

Nenhuma hierarquia universal se aplica a todas as auditorias, mas as evidências geradas directamente a partir de sistemas autoritários são geralmente mais fortes do que a auto-aprovação. Uma ordem prática de preferência é:

1. Registos independentemente gerados ou externamente corroborados;
2. exportações geradas pelo sistema com os parâmetros fonte, timestamp, escopo e consulta;
3. Registos aprovados criados durante operações normais;
4. Observação directa ou nova performance documentada pelo avaliador;
5. entrevistas corroboradas por registros ou observação;
6. representação de gestão ou auto-aprovação.

Evidências inferiores não são automaticamente inválidas. Requer maior corroboração e limitações mais claras.

1.5 Julgamento profissional

A avaliação de evidências requer julgamento profissional. O revisor deve considerar o risco, a materialidade, o tamanho da população, a frequência do controle, a automação, a mudança, as descobertas anteriores, o risco de fraude, o risco de segurança da informação e as consequências de uma conclusão incorreta. O trabalho deve registrar julgamentos significativos em vez de deixá-los implícitos.

1.6 Práticas proibidas

Não:

- Criar ou alterar elementos de prova após o facto sem divulgação;
 - remover registos desfavoráveis de uma população;
 - representar capturas de tela como evidência completa do sistema quando os dados subjacentes não estiverem disponíveis;
 - Partilhar credenciais ou acesso irrestrito à produção com auditores;
 - Colocar provas regulamentadas, privilegiadas ou altamente sensíveis em repositórios não aprovados;
 - substituir os ficheiros de provas originais;
 - Basear-se em declarações verbais como o único apoio às conclusões de alto risco; ou
 - etiquetar os controlos automatizados como aprovação legal, regulamentar, de certificação ou de auditoria humana.
-

2. Planejamento, Pedidos e Responsabilidades

2.1 Começar pelo objectivo de avaliação

Antes de solicitar provas, definir:

- O objetivo de auditoria, avaliação, revisão ou certificação;
- Os critérios e a versão autorizados;
- O âmbito organizacional, técnico, geográfico e temporal;
- Sistemas, processos, entidades e populações em âmbito;
- O controlo ou o requisito em causa;
- O tipo de prova esperado;
- O método de avaliação: examinar, entrevistar, testar, observar, inspeccionar ou rever;
- O requerente responsável, proprietário, revisor e aprovador; e
- A data de conclusão exigida.

Um pedido sem um critério ou objectivo definidos gera encargos desnecessários e enfraquece a rastreabilidade.

2.2 Estrutura do pedido de provas

Cada pedido deve incluir:

- pedido único ID;
- ID de auditoria ou de compromisso;
- Critérios ou referência de controlo;
- Descrição do pedido em língua simples;
- Razão pela qual as provas são necessárias;
- período e população solicitados;
- Formatos aceitáveis;
- metadados ou contexto necessários;
- canal de submissão seguro;
- proprietário e proprietário de reserva atribuído;
- Data de vencimento e prioridade;
- Classificação de confidencialidade;
- Critérios de aceitação do revisor; e
- dependências ou pedidos pré-requisitos.

Evitar a combinação de provas não relacionadas num único pedido. Dividir grandes pedidos em itens gerenciáveis com critérios de aceitação claros.

2.3 Funções

Patrocinador da auditoria

Aprova o âmbito de aplicação, resolve conflitos significativos e apoia a cooperação atempada.

Auditoria ou pista de avaliação

Possui a estratégia de evidência, lista de pedidos, abordagem de amostragem, atribuições de revisor, qualidade de conclusão e escalada.

Coordenador de provas

Mantém o rastreador de pedidos, encaminha perguntas, monitora datas de vencimento e evita solicitações duplicadas ou conflitantes.

Controlar ou processar o proprietário

Explica o processo, valida o escopo e garante que a evidência reflete com precisão as operações normais.

Custódia de provas

Extraí ou fornece registros da fonte autoritária, preservando a integridade e metadados.

Revisor ou testador

Avalia a relevância, confiabilidade, suficiência, adequação, exceções e limitações e registra a conclusão.

Jurídico, privacidade, segurança, recursos humanos e especialistas em registros

Aconselhar sobre privilégios, dados pessoais, investigações sensíveis, informações dos funcionários, restrições de exportação, limites contratuais, contenciosos e retenção segura.

2.4 Solicitar ciclo de vida

Utilizar os seguintes estados:

1. Rascunho
2. Aprovado para emissão
3. Emitido
4. Entendido.
5. Em curso
6. Apresentado
7. Em revisão
8. Esclarecimento necessário
9. Aceitado
10. Rejeitado ou substituído
11. Fechado
12. Retido ou eliminado

As alterações de estatuto devem ser datadas e imputáveis. Os pedidos reabertos devem preservar as submissões prévias e o histórico de revisão.

2.5 Datas de vencimento e escalonamento

Defina datas de vencimento com base na complexidade, risco, disponibilidade e no cronograma de engajamento. A escalada deve ser proporcional:

- lembrete ao proprietário;
- Coordenação com o proprietário do apoio;
- Notificação ao gestor de processos;
- escalada do chumbo de engajamento;
- A escalada para patrocinar ou órgão de governação; e
- limitação do âmbito formal de aplicação quando não for possível obter provas.

As provas tardias não devem ser tratadas silenciosamente como satisfatórias. Registrar o atraso, o impacto, a atenuação e a conclusão revista.

2.6 Pedidos duplicados e excessivos

O coordenador de provas deve comparar os pedidos de auditoria interna, auditoria externa, conformidade, garantia do cliente, segurança, privacidade e atividades de certificação. Reutilizar as provas apenas quando o período, âmbito, critério, integridade, confidencialidade e frescura se mantiverem adequados. A reutilização deve ser documentada; não deve ocultar alterações ou novas exceções.

3. Coleta, Integridade e Proteção

3.1 Recolha de fontes autorizadas

Identificar o sistema de registro, proprietário de registro, método de extração, data e hora, parâmetros de consulta ou filtro, tamanho da população e pessoa que realiza a extração. Preservar arquivos de origem brutos quando práticos e criar cópias de trabalho para revisão.

3.2 Exportações do sistema

Um sistema de exportação deve incluir um contexto suficiente para interpretar os dados:

- Nome do sistema e do ambiente;
- relatório ou nome da consulta;
- Hora de extração e fuso horário;
- Período de referência;
- Filtros e exclusões;
- Definições de campo quando não for claro;
- população total e contagem de linhas;
- Conta de utilizador ou de serviço que produziu a exportação; e
- limitações conhecidas.

Quando uma exportação é transformada manualmente, reter o original, gravar cada transformação, e conciliar totais antes e após o processamento.

3.3 Imagens

Capturas de tela são úteis para configuração ponto-em-tempo, fluxo de trabalho e evidência de interface, mas eles são facilmente incompletos. Capturar:

- aplicação e ambiente;
- Data visível do sistema ou data de captura documentada;
- URL, objeto, inquilino, conta ou identificador de registro relevantes sem expor segredos desnecessários;
- O conjunto completo e o contexto circundante;
- paginação, filtros e âmbito; e

- O operador e o método de captura.

Não recorte o contexto que afeta a interpretação. A redistribuição deve utilizar um método aprovado e não deve alterar os elementos de prova substantivos.

3.4 Documentos e registos

Confirme o estado de aprovação, proprietário, versão, data efetiva, data de revisão, histórico de alterações e aplicabilidade. Uma política prova intenção documentada; não prova por si só implementação ou operação.

3.5 Entrevistas e observações

Documentar papéis dos participantes, data, perguntas, declarações-chave, atividades observadas, limitações e registros corroborantes. Fornecer ao entrevistado uma oportunidade para corrigir mal-entendidos factuais, quando apropriado. As entrevistas não devem ser apresentadas como prova independente quando devem existir provas operacionais mais fortes.

3.6 Repercussão e testes

Grave o procedimento, entradas, ferramentas, testador, data, ambiente, resultado esperado, resultado real, exceções e saída retida. Os testes devem ser autorizados e projetados para evitar danos operacionais, violações de privacidade ou acesso não autorizado.

3.7 Autenticidade e integridade

Utilizar controlos proporcionais, tais como:

- Recuperação apenas de leitura;
- Os repositórios de provas restritos;
- ficheiro hashes;
- Assinaturas digitais ou datas de confiança;
- Armazenamento imutável ou versionado;
- Acesso e descarregamento de registos;
- reconciliação entre sistemas de origem;
- Confirmação independente; e
- cadeia de custódia documentada.

Um hash ajuda a detectar alterações de arquivos após o hashing; ele não prova que o conteúdo original era preciso ou completo.

3.8 Cadeia de custódia

Para material de alto risco, investigativo, legal ou forense, registre cada transferência, manipulador, tempo, local, finalidade, ação e verificação de integridade. Usar armazenamento selado ou controlado pelo acesso e preservar originais. Escale imediatamente se a custódia ou integridade for incerta.

3.9 Confidencialidade e minimização

Recolha as provas mínimas necessárias. Redigir ou tokenizar dados pessoais, segredos, credenciais, chaves privadas, informações de saúde, dados de pagamento, aconselhamento legal e informações de funcionários não relacionados quando o objetivo de avaliação não requer divulgação. Nunca envie e-mail credenciais irrestritas ou coloque evidências sensíveis no armazenamento pessoal.

3.10 Provas transfronteiriças e de terceiros

Confirmar direitos contratuais, residência de dados, restrições de transferência, obrigações de confidencialidade, requisitos de regulador e consentimento de terceiros antes da coleta ou divulgação. Registre qualquer limitação que impeça o acesso direto e a garantia alternativa obtida.

4. Revisão, Amostragem e Conclusões

4.1 Sequência de revisão

Para cada apresentação, o revisor deve determinar:

1. Responde ao pedido e ao critério?
2. A fonte é autoritária e identificável?
3. Abrange a entidade correta, sistema, período, população e frequência de controle?
4. A evidência é completa, autêntica, protegida e internamente consistente?
5. O resultado pode ser corroborado ou reproduzido?
6. São registradas exceções, lacunas, suposições e limitações?
7. São necessárias provas adicionais antes de se chegar a uma conclusão?

4.2 Resultados da revisão de provas

Utilizar resultados controlados como:

- Aceitado;
- Aceitado com limitação;
- clarificação necessária;
- Provas adicionais exigidas;
- Substituição necessária;
- Não aplicável com fundamentação aprovada;
- Rejeitado; e
- limitação do âmbito de aplicação.

O revisor deve registrar a base para o resultado, não apenas o status.

4.3 População e amostragem

Defina a população antes de selecionar amostras. Documento:

- Fonte e proprietário da população;
- período abrangido;
- contagem populacional;
- Regras de inclusão e exclusão;
- estratificação ou factores de risco;
- Método de amostragem;
- Tamanho e lógica da amostra;
- Procedimento de seleção ou de seleção aleatória, quando aplicável;
- Substituições e razões; e
- Limitações que afectam a representatividade.

A amostragem pode ser estatística ou crítica. Não implica confiança estatística quando uma amostra crítica foi utilizada.

4. 4 Considerações relativas ao desenho da amostra

Aumentar a cobertura quando o risco, materialidade, frequência de controle, volume de transação, mudança, falha de automação, descobertas anteriores, exposição à fraude ou variabilidade populacional é alta. Considere selecionar:

- Itens de alto valor ou alto risco;
- Transações pouco usuais ou mal sucedidas;
- Novos sistemas ou processos;
- diferentes locais, unidades de negócio, administradores e períodos de tempo;
- Artigos antes e depois de grandes alterações; e
- foram selecionados aleatoriamente itens comuns.

4.5 Excepções

Uma exceção é uma diferença entre o critério e a condição observada. Gravar:

- Amostra ou identificador da população;
- Critérios;
- condição prevista;
- condição observada;
- Referência de provas;
- causar, quando conhecido;
- Consequências ou riscos;
- Se a exceção é isolada ou sistémica;
- Controlos compensadores;
- Resposta do proprietário; e
- seguimento necessário.

Não remova uma exceção do registro apenas porque ele é corrigido durante a auditoria. Registre a condição original e a remediação verificada separadamente.

4. 6 Corroboração

Corroborate evidência fraca ou de alto risco usando outra fonte, método, período de tempo, ou parte independente. Exemplos incluem comparar os requisitos de política com a configuração do sistema, conciliar as exportações com os totais de origem, observar um processo descrito em uma entrevista ou traçar uma amostra através da iniciação, aprovação, execução e monitoramento.

4.7 Conclusões

As conclusões devem indicar:

- O critério e o objectivo;
- Âmbito e período;
- Procedimentos realizados;
- Os elementos de prova revistos;
- Limitações da amostra e da população;
- As exceções e o seu significado;
- Controlos compensadores;
- Discordâncias não resolvidas;
- A conclusão do revisor; e
- acção ou escalada necessária.

Evitar alegações absolutas, tais como “completamente conformes” ou “seguras”, quando os procedimentos e provas suportam apenas uma conclusão mais estreita.

4.8 Revisão e controle de qualidade

As conclusões significativas deverão ser objecto de revisão da supervisão. O revisor deve confirmar que os trabalhos são compreensíveis sem explicação oral, as referências resolvem a evidência retida, os cálculos são corretos, as exceções são rastreáveis, e a conclusão vem da evidência.

5. Coordenação e Remediação do Auditor

5.1 Canal único de coordenação

Use um coordenador de evidências ou portal controlado para direcionar solicitações, submissões, perguntas e atualizações de status. Isso reduz solicitações duplicadas, respostas inconsistentes, divulgação descontrolada e perda de histórico de auditoria.

5.2 Alinhamento de abertura

No início do noivado, confirme:

- Âmbito e critérios;
- Período de auditoria e etapas;
- Processo de solicitação e escalada;
- Método de intercâmbio seguro de provas;
- Tempos de resposta esperados;
- Formatos de prova autorizados;
- A amostragem e as expectativas de acompanhamento;
- Regras aplicáveis aos materiais privilegiados, regulamentados, pessoais ou restritos;
- Cadência de reunião; e
- Processo para observações preliminares e correções factuais.

5.3 Clarificações

Quando uma solicitação é ambígua, peça ao solicitante para esclarecer o critério, período, população, sistema e evidência esperada. Não adivinhe e forneça dados excessivos. Gravar interpretações acordadas no registo de pedidos.

5.4 Acesso ao Auditor

Prefere demonstrações supervisionadas, contas somente leitura, acesso limitado ao tempo, dados mascarados, exportações controladas ou salas de dados virtuais seguras. Aplicar menos privilégio e monitorar o acesso. Nunca forneça credenciais de administrador compartilhado, credenciais pessoais, chaves privadas ou acesso à produção sem restrições.

5.5 Observações preliminares

Uma observação preliminar deve identificar o critério, condição, evidência, risco e escopo afetado. A gestão deve distinguir as correções factuais do desacordo com o acórdão do auditor. As correções devem ser apoiadas por evidências e não devem reescrever a história.

5.6 Respostas de gestão

Uma resposta completa inclui:

- Acordo, acordo parcial ou desacordo;
- Contexto factual;
- causa da raiz;
- Avaliação dos riscos;
- Contenção imediata;
- Medidas corretivas;
- O proprietário responsável;
- Data-alvo;
- recursos e dependências;

- Controlos intercalares;
- Método de validação; e
- provas que demonstrem o encerramento.

Evite respostas que apenas prometem “rever”, “considerar” ou “lembrar pessoal.”

5.7 Seguimento da acção correctiva

Acompanhe cada achado através de:

1. observação registada;
2. Validação factual;
3. notação de risco acordada ou formalmente contestada;
4. Plano de acção aprovado;
5. Execução em curso;
6. Provas de gestão apresentadas;
7. Validação independente realizada;
8. Aprovação do encerramento; ou
9. risco formalmente aceite ou aumentado.

As datas revistas e as alterações de âmbito deverão preservar o histórico de compromisso e aprovação inicial.

5.8 Provas de encerramento

O encerramento requer provas de que a acção acordada foi implementada e está a funcionar de forma eficaz. Dependendo do achado, isso pode requerer documentação atualizada, evidência de configuração, populações completas, resultados de testes, registros de treinamento, relatórios de monitoramento ou um período de operação sustentada.

Uma tarefa concluída não significa automaticamente que o risco subjacente seja reduzido.

5.9 Desacordos e limitações de âmbito

Documentar desacordos não resolvidos, evidências indisponíveis, restrições de acesso, recusas de gestão e restrições de tempo. Escale-os para o patrocinador de engajamento ou órgão de governança. O relatório final deve explicar como os procedimentos de limitação e a confiança na conclusão foram afetados.

6. Retenção, encerramento e melhoria contínua

6. 1 Repositório de provas

Use um repositório aprovado com controle de acesso baseado em funções, criptografia, histórico de versões, backup, registro e retenção. Organize evidências por engajamento, critério,

solicitação de ID e versão de submissão. Não depende de caixas de correio pessoais, downloads locais, anexos de bate-papo ou links temporários como registro oficial.

6. 2 Nomeação e indexação de arquivos

Uma convenção de nomeação prática inclui:

Engagement_RequestID_Criterion_Period_Source_Version

O índice deve mapear cada arquivo para:

- ID do pedido;
- Critérios;
- Detentor de provas;
- Sistema de origem;
- período;
- Data de apresentação;
- Classificação;
- Revisor;
- rever os resultados;
- Identificação ou referência de documentos de trabalho; e
- Data de retenção ou eliminação.

6. 3 Esquema de retenção

Aplique o cronograma de registros da organização, obrigações contratuais, requisitos reguladores, contencioso, necessidades de investigação e metodologia de auditoria. Reter provas não mais do que justificadas, mas não destruir registros sujeitos a uma detenção legal, investigação aberta, pedido de preservação regulamentar, conclusão não resolvida ou recurso activo.

O registo de empenhamento deve identificar a regra de controlo da retenção e a autoridade de eliminação.

6.4 Eliminação segura

Quando a retenção autorizada expira:

- Confirmar que não se aplica qualquer dependência de detenção ou não resolvida;
- Obter a homologação exigida;
- remover cópias de trabalho e conjuntos de dados exportados;
- Utilizar um método de destruição aprovado;
- preservar um diário de eliminação; e
- Verificar a exclusão de locais de colaboração e locais de transferência temporária sempre que possível.

6.5 Encerramento do noivado

Antes de fechar, confirme:

- Todos os pedidos têm um estatuto final;
- Os elementos de prova aceites são indexados e acessíveis;
- As observações rejeitadas e substituídas continuam a ser rastreáveis quando necessário;
- Os documentos de trabalho referem as versões correctas das provas;
- Os resultados e as respostas de gestão são finalizados;
- São comunicadas limitações não resolvidas;
- As ações corretivas são transferidas para o rastreador oficial;
- Os direitos de acesso são suprimidos ou reduzidos;
- as ligações de partilha temporárias expiram;
- São atribuídas datas de retenção e eliminação; e
- as lições aprendidas são registradas.

6.6 Métricas

As medidas úteis incluem:

- Pedidos emitidos, aceites, rejeitados, atrasados e reabertos;
- tempo médio para reconhecer, apresentar, rever e encerrar;
- Taxa de aceitação da primeira passagem;
- Taxa de pedido duplo;
- Número de incidentes de confidencialidade ou de acesso;
- Percentagem de provas provenientes de sistemas autorizados;
- Percentagem de resultados com planos de acção completos;
- ações corretivas atrasadas;
- A recorrência dos resultados anteriores; e
- Correções de controlo de qualidade do revisor.

A métrica deve melhorar o processo, não recompensar a aceitação prematura ou desencorajar o desafio legítimo.

6.7 Lições aprendidas

Após cada compromisso principal, documento:

- Pedidos pouco claros ou excessivos;
- Falhas recorrentes na qualidade das provas;
- Limitações do sistema;
- trabalho manual desnecessário;
- Problemas de acesso ou confidencialidade;
- Confusão de controlo-proprietário repetida;
- oportunidades de relatórios reutilizáveis ou de provas automatizadas; e

- Alterações necessárias na política, formação, sistemas ou modelos.

6.8 Disponibilidade contínua de provas

As organizações devem integrar a geração de evidências em operações normais. Os proprietários de controle devem saber quais registros demonstram desempenho, onde eles são mantidos, e como eles são revistos. A coleta automatizada de evidências pode reduzir o esforço, mas deve preservar o contexto, o controle de acesso, a integridade, a rastreabilidade da fonte e a responsabilidade humana.

6.9 Princípio de funcionamento final

O objectivo não é produzir o maior pacote de provas. O objetivo é produzir um corpo controlado, proporcional e rastreável de evidências que apoie uma conclusão honesta e permita uma ação responsável.

Apêndice A — Modelos operacionais

O pacote de publicação inclui as seguintes ferramentas CSV editáveis:

- **Audit_Request_and_Response_Log.csv** — 21 campos.
- **Corrective_Action_Tracker.csv** — 32 campos.
- **Evidence_Quality_Review_Checklist.csv** — 36 campos.
- **Evidence_Request_Tracker.csv** — 38 campos.

Registo Autoritativo de Código

Verificado em 1 de agosto de 2026.

Fontes primárias

1. **NIST SP 800-53A Rev. 5 — Avaliando os Controles de Segurança e Privacidade em Sistemas e Organizações de Informação.** Janeiro 2022, com Release 5.2.0 assessment-procedure atualizações emitidas em 27 agosto 2025. Fornece procedimentos de avaliação personalizáveis, orientações do plano de avaliação e métodos para análise dos resultados da avaliação.
2. **NIST SP 800-53 Rev. 5 — Controles de Segurança e Privacidade para Sistemas e Organizações de Informação.** Setembro 2020, com lançamento 5.2.0 atualizações emitidas 27 agosto 2025. Fornece os objectivos de controlo e o contexto de garantia relativamente aos quais podem ser avaliadas as provas.
3. **ISO 19011:2026 — Diretrizes para sistemas de gestão de auditoria.** Edição 4, publicada em maio de 2026. Supera a edição retirada da ISO 19011:2018 e aborda princípios de auditoria, gestão de programas de auditoria, realização de auditorias e competência de auditor.

4. **U.S. GAO, Normas de Controle Interno no Governo Federal (2025 Green Book), GAO-25-107721.** Publicado em 15 de maio de 2025 e início efetivo do exercício de 2026. Enfatiza documentação de avaliação de risco, projeto de controle, implementação, operação e respostas a mudanças significativas.
5. **** Instituto de Contas Internas, Global Internal Audit Standards.**** Emitido em 9 de janeiro de 2024 e efetivo em 9 de janeiro de 2025. Estabelece requisitos baseados em princípios e exemplos de provas de conformidade para a prática profissional de auditoria interna.

Regras de controle-fonte

- Verifique as versões atuais antes de cada versão principal.
- Distingue critérios obrigatórios das orientações e exemplos.
- Não reproduzir padrões com direitos autorais além de resumos e citações permitidas.
- Registre o critério, versão, data de publicação e data de acesso em documentos de auditoria.
- Quando os critérios em conflito, aumentar para o patrocinador de auditoria, advogado, proprietário de conformidade, ou especialista qualificado, em vez de silenciosamente selecionar um.